

Audit et Gestion de la Sécurité des SI : Flashcard complet

? 01-Q : C'est quoi un Système d'Information (SI) ?

R : Un système d'information est l'ensemble des ressources (matériels, logiciels, données, procédures, humaines, données, procédures ...) structurés pour acquérir, traiter, stocker, et diffuser l'information de toutes formes (sous forme de données, textes, sons, images, ...) pour soutenir la prise de décision et le contrôle dans une organisation (entreprise).

? 02-Q : Est-il vrai que le périmètre du SI est identique pour toutes les organisations ?

R : Non, elle peut être très différent d'une organisation à une autre

? 03-Q : Quels sont les éléments qui peuvent être recouvert par le périmètre du SI ?

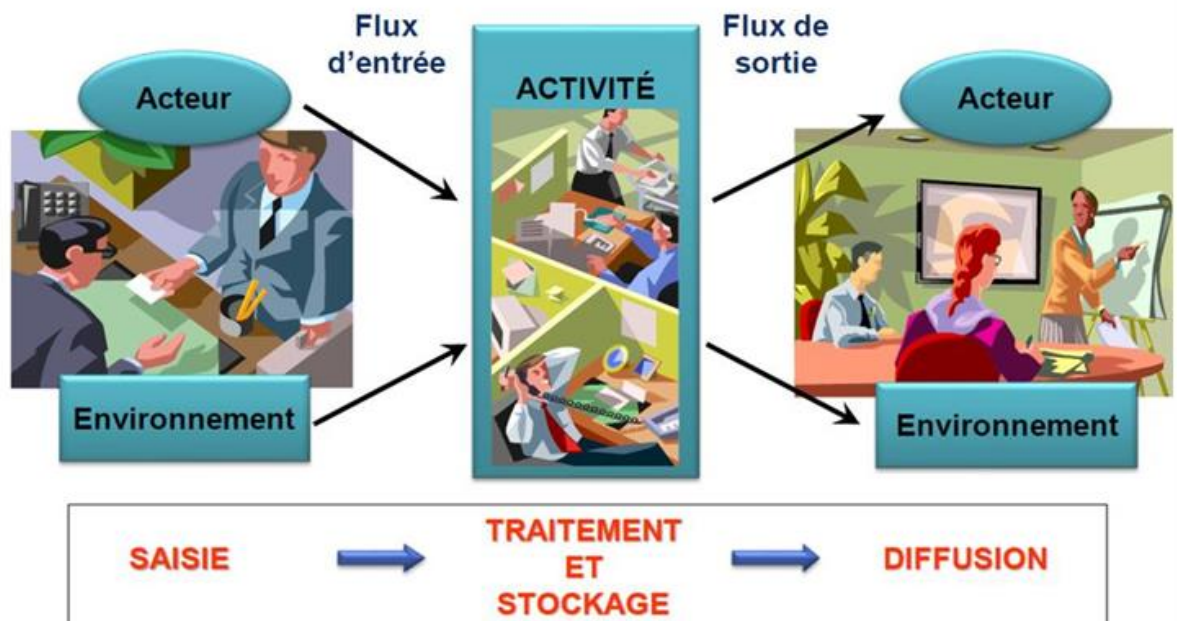
R : Les éléments :

- ❖ Bases de données de l'entreprise,
- ❖ Progiciel de gestion intégré (ERP),
- ❖ Outil de gestion de la relation client,
- ❖ Outil de gestion de la chaîne logistique,
- ❖ Applications métiers,
- ❖ Infrastructure réseau/télécommunication
- ❖ Serveurs de données et systèmes de stockage,
- ❖ Serveurs d'application.

? 04-Q : Peut tu grâce à un schéma expliqué les fonctions du SI ?

R : Fonctions du SI :

Les Fonctions du SI



? 05-Q : Les fonctions des SI peuvent être organisées en 4 grandes parties, cite et décris-les

R :

- **Collecter l'information:** Enregistrer une information (support papier, informatique...) avant son traitement
- **Mémoriser l'information (stockage) :** Conserver, archiver (utilisation ultérieure ou obligation légale)
- **Traiter l'information :** effectuer des opérations (calcul, tri, classement, résumé, ...)
- **Diffuser :** transmettre à la bonne personne (éditer, imprimer, afficher, ... une info après traitement)

? 06-Q : C'est quoi la Sécurité informatique ?

R : C'est toutes **mesures et contrôles** qui garantissent la **confidentialité**, l'**intégrité** et la **disponibilité** des actifs du système d'information, y compris le matériel, les logiciels, les micro logiciels et les informations traitées, stockées et communiquées.

? 07-Q : C'est quoi la Sécurité des informations ?

R : C'est la **protection des informations et des systèmes d'information** contre l'accès, l'utilisation, la divulgation, la perturbation, la modification ou la destruction non autorisés afin d'assurer la confidentialité, l'intégrité et la disponibilité.

? 08-Q : C'est quoi la sécurité des systèmes d'information ?

R : C'est la **protection des informations et des systèmes d'information** contre l'accès ou la modification non autorisés des informations, qu'elles soient stockées, traitées ou en transit, et contre le déni de service aux utilisateurs autorisés. La sécurité de l'information comprend les mesures nécessaires pour détecter, documenter et contrer de telles menaces. La sécurité de l'information est composée de la sécurité informatique et de la sécurité des communications.

? 09-Q : C'est quoi la cybersécurité ?

R : C'est toute activité visant la **défense** des ordinateurs, des serveurs, des appareils mobiles, des systèmes électroniques, des réseaux et des données **contre les attaques malveillantes** qui vont des organisations commerciales aux appareils personnels.

? 10-Q : Défini un Ressource système

R : Une application majeure, un système de support général, un programme à impact élevé, une installation physique, un système critique pour la mission, du personnel, de l'équipement ou un groupe de systèmes logiquement liés.

? 11-Q : C'est quoi une Vulnérabilité ?

R : C'est une faille détectée dans la conception du matériel ou du logiciel et qui peut être exploitée pour obtenir un accès non autorisé au système.

? 12-Q : C'est quoi une Menace ?

R : Toute circonstance ou événement susceptible d'avoir un impact négatif sur les opérations de l'organisation (y compris la mission, les fonctions, l'image ou la réputation), les actifs de l'organisation, les individus, ou la nation, via un accès non autorisé au système, déclenchant

ainsi la destruction, la divulgation, la modification, et/ou déni de service du système d'information.

? 13-Q : C'est quoi une Attaque ?

R : C'est tout ensemble d'action qui essayent d'exploiter une ou plusieurs failles du système à travers une ou plusieurs menaces détectées afin de compromettre :

- 1- Confidentialité : exemple vol de mot de passe
- 2- Intégrité : exemple modification illégitime de fichier
- 3- Disponibilité : exemple destruction illégitime ou abusive de ressource
- 4- Authenticité : exemple employeur qui utilise agrément de son chef pour ses justifications d'absence

? 14-Q : C'est quoi un Risque ?

R : C'est une mesure dans laquelle une entité est menacée par une circonstance ou un événement potentiel, et généralement en fonction des impacts négatifs qui surviendraient si la circonstance ou l'événement se produisait et de la probabilité d'occurrence.

? 15-Q : C'est quoi un Adversaire (ou agent menaçant) ?

R : C'est un individu, un groupe, une organisation ou un gouvernement qui mène ou a l'intention de mener des activités dommageables (préjudiciable).

? 16-Q : C'est quoi un Contre-mesure ?

R : C'est un dispositif ou des techniques qui ont pour objectif de nuire à l'efficacité opérationnelle d'une activité indésirable ou accusatoire, ou de prévenir l'espionnage, le sabotage, le vol ou l'accès ou l'utilisation non autorisés d'informations ou de systèmes d'information sensibles.

? 17-Q : C'est quoi une Politique de sécurité ?

R : C'est un ensemble de critères pour la fourniture de services de sécurité. Il définit et contraint les activités d'une installation de traitement de données afin de maintenir un état de sécurité des systèmes et des données.

? 18-Q : Il est possible d'appliquer différent niveau de sécurité au sein d'une entité informatique, tel qu'un Entreprise. Quels sont ces niveaux de sécurité ?

R : Niveau de sécurité :

- 1- Sécurité du réseau
- 2- Sécurité des applications
- 3- Sécurité des informations
- 4- Sécurité opérationnelle
- 5- Reprise après sinistre
- 6- Continuité des activités

NB : La reprise après sinistre est associée à la réaction d'une organisation en cas de perte de données et tente de restaurer ses capacités opérationnelles afin de poursuivre le fonctionnement de l'organisation.

? 19-Q : Cite les différentes catégories d'attaque que tu connais

R : Catégories d'attaque :

- 1- Cybercriminalité (ciblant un gain financier)
- 2- Cyberattaques (principalement des attaques politiques)
- 3- Cyberterrorisme
- 4- Phishing
- 5- SQL Injection
- 6- DDoS (déni de service)

? 20-Q : Cite différent outils ou logiciel permettant d'orchestrer des attaques

R : Outils/Logiciel :

- 1- Virus
- 2- Chaval de Troie
- 3- Ransomware
- 4- Adware (logiciels publicitaires)
- 5- Botnet (réseaux de zombies)

? 21-Q : La sécurité des SI repose sur 3 pilier fondamental, cite et décris-les

R : Les 3 pilier fondamental de sécurité des SI :

- 1- **Confidentialité (Confidentiality)** : elle garantit que les informations privées ou confidentielles ne sont pas mises à disposition ou divulguées à des personnes non autorisées. Elle assure également la

vie privée des individus en contrôlant qui peuvent collecter et stocké des informations les concernant et à qui ces informations peuvent être divulguée. L'une des principales techniques pour assurer la confidentialité consiste à utiliser la cryptographie, qui consiste à brouiller les informations afin qu'elles deviennent illisibles par quiconque ne possède pas la clé de cryptage.

- 2- **Intégrité (Integrity)** : L'intégrité garantit l'exactitude et l'exhaustivité des données tout au long de leur cycle de vie. Cela signifie que **les données ne peuvent pas être modifiées de manière non autorisée ou non détectée**. Le mécanisme de garantie de l'intégrité implique souvent l'utilisation d'une fonction de hachage, une fonction mathématique à sens unique qui fournit une signature numérique des données à protéger.
- 3- **Disponibilité (Availability)** : Elle garantit que le service reste accessible à tout moment aux utilisateurs autorisé, peut importe les problèmes qui pourrait intervenir, comme les pannes de courant, pannes matérielles, attaques par déni de service, etc.

? 22-Q : Cite tous les Intervenants et Rôles dans SSI (Sécurité des Systèmes d'Information)

R : Intervenants et Rôles :

- 1- **DG** (Directeur Général)
- 2- **DSI** (Directeur du Système d'Information)
- 3- **RSSI** (Responsable de la Sécurité du Système d'Information)
- 4- Membres de l'Equipe de Sécurité
- 5- **RP** (Responsable de la Production)
- 6- Administrateurs
- 7- **RE** (Responsable des Etudes)
- 8- Chefs de projet
- 9- Directeurs de Service
- 10- Responsable Qualité
- 11- Utilisateurs du SI

? 23-Q : Décris Cite tous les Intervenants et Rôles dans SSI

R : Description :

❑ Le Directeur Général (DG)

- ❖ Il fournit les moyens humains et financiers pour assurer la sécurité du systèmes d'information de la société;
- ❖ Il valide l'ensemble des risques ainsi que le plan de traitement des risques présentés par le RSSI, au moins une fois par an;
- ❖ Il valide la politique de sécurité du système d'information (PSSI).

❑ Le Directeur du Système d'Information(DSI)

- ❖ Il nomme le RSSI à qui il délègue le pilotage des actions de sécurisation du SI;
- ❖ Il définit et tient à jour avec le RSSI les objectifs en matière de sécurité du SI;
- ❖ Il valide les risques portant sur les infrastructures dont il a la responsabilité, que lui présente le RSSI;
- ❖ Il valide et alloue les budgets nécessaires à la mise en place ainsi qu'à l'exploitation de mesures de sécurité.

❑ Le responsable de la sécurité du système d'information (RSSI)

- ❖ Il **définit** et met en œuvre **les plans d'actions pour sécuriser** le SI;
- ❖ Il s'assure du **bon fonctionnement des mesures de sécurité** existantes;
- ❖ Il **définit la politique de sécurité** du système d'information et la maintient à jour;
- ❖ Il **réalise et maintient une appréciation des risques sur la sécurité** pour l'ensemble du SI et fait valider aux différents responsables concernés;
- ❖ Il **réalise une veille technologique** afin d'adapter les mesures de sécurité aux nouvelles menaces, et **une veille sur la vulnérabilités** afin de prévenir les attaques.

❑ Les membres de l'équipe de sécurité

- ❖ Il assiste le RSSI dans ses missions;
- ❖ Il déclinent opérationnellement les règles définies par la politique de sécurité;
- ❖ Il effectuent les tâches de contrôle continu et de contrôle récurrent des mesures de sécurité:
- ❖ Contrôle contre les codes malveillants;
- ❖ Contrôles contre les intrusions dans le réseau;
- ❖ Revues périodiques des droits;

□ **Le responsable de la production**

- ❖ Il est le garant du respect par ses équipes de l'application de la politique de sécurité;
- ❖ Il décline les règles de sécurité s'appliquant aux systèmes dont il a la responsabilité;
- ❖ Il informe le RSSI de tout incident de sécurité survenu dans son domaine de responsabilité;
- ❖ Il exploite les mesures de sécurité dont il a reçu la délégation.

□ **Les administrateurs**

- ❖ Il exploitent au quotidien le système d'information conformément aux directives de la politique de sécurité;
- ❖ Ils mettent en œuvre les procédures de sécurité applicables dans leurs fonctions;
- ❖ Ils informent le RSSI de tout incident de sécurité ou de toute situation anormale.

□ **Les responsable des études**

- ❖ Il est le garant du respect par ses équipes des règles de sécurité fixées dans la politique de sécurité;
- ❖ Il consulte le RSSI pour toute question relative à la sécurité du SI;
- ❖ Il informe le RSSI de tout incident de sécurité détecté par ses équipes.

□ **Les chefs de projet**

- ❖ Ils intègrent les aspects de sécurité du SI dans les projets dont ils ont la charge;
- ❖ Ils s'assurent que les directives incluses dans la politique de sécurité du SI sont bien prises en compte dans leur domaine de responsabilité;
- ❖ Ils informent le RSSI en cas d'incident de sécurité.

□ **Les directeurs de service:**

- ❖ Ils s'assurent que leurs équipes réalisent correctement les revues de droits sur les différentes applications du service;
- ❖ Ils sont garants de la bonne application de la politique de sécurité et du respect de la charte utilisateur par leurs équipes;
- ❖ Ils valident les risques applicables à leur périmètre de responsabilité;
- ❖ Ils informent le RSSI de tout incident de sécurité.

❑ **Le responsable qualité**

- ❖ Il s'assure que les procédures intégrées au système de management de la qualité (SMQ) sont à jour;
- ❖ Il contrôle que les procédures de sécurité, intégrées dans le SMQ sont conformes aux exigences du système.

❑ **Les utilisateurs du SI**

- ❖ Ils respectent la charte de bon usage des moyens informatiques qui est annexée au règlement intérieur de la société;
- ❖ Ils utilisent systématiquement les moyens informatiques mis à leur disposition par la DSI, et conforme aux procédures en vigueur;
- ❖ Ils remontent au service d'assistance, et dans les plus bref délai, tout événement pouvant s'avérer être un incident de sécurité.